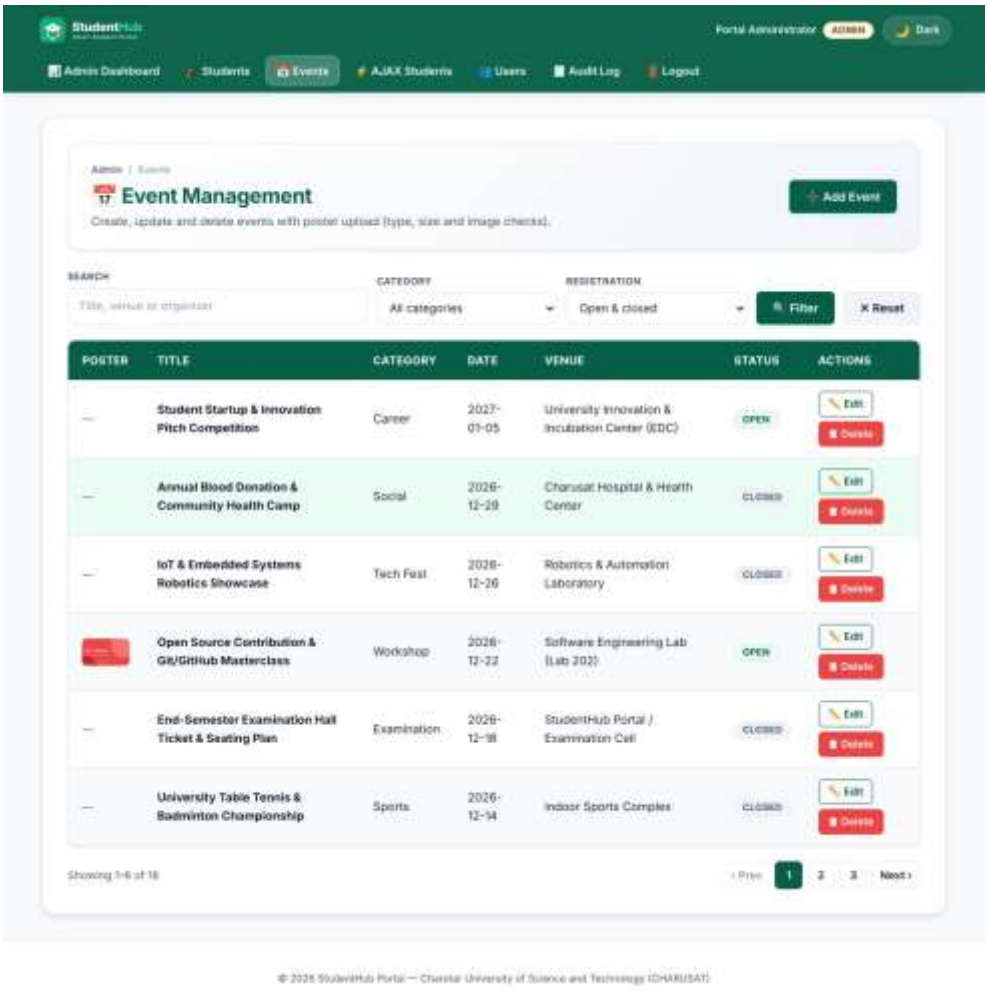
PRACTICAL-12

AIM: Build event management (CRUD) with poster upload, server-side upload validation and success/failure messages.

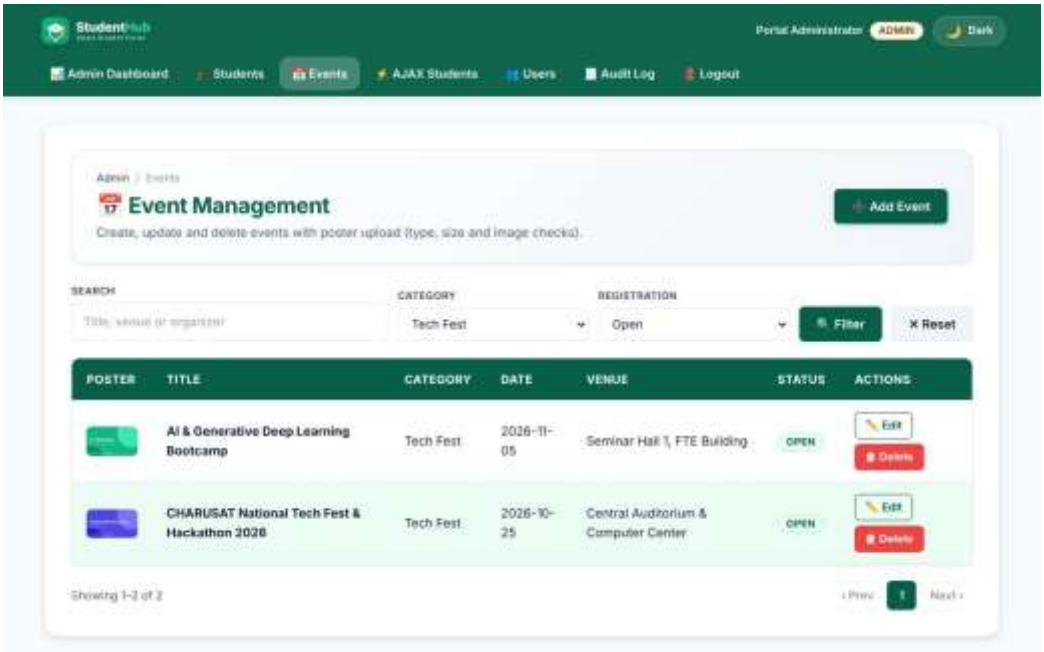
SOURCE CODE :

https://github.com/rachhadiyabrind-del/WDF_B/tree/main/Practical(1-4)(Studenthub)/Practical-12

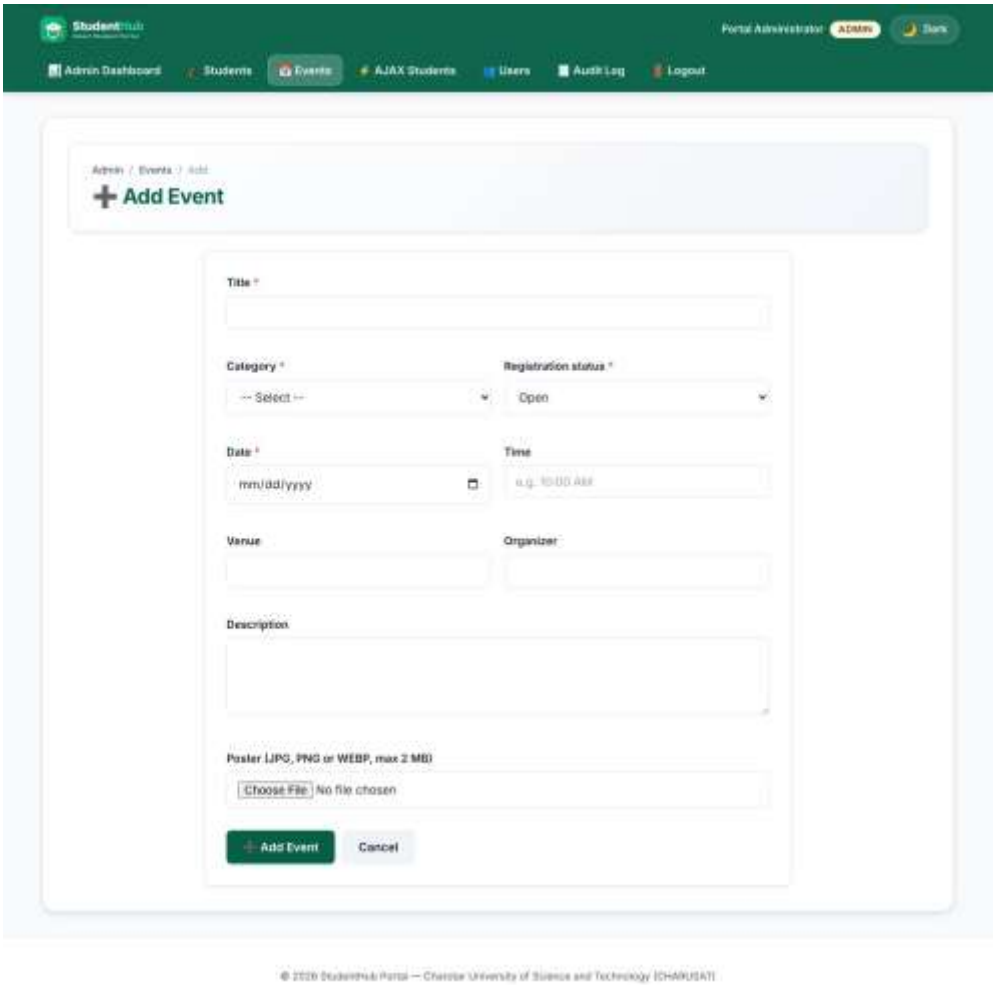
PREVIEW:



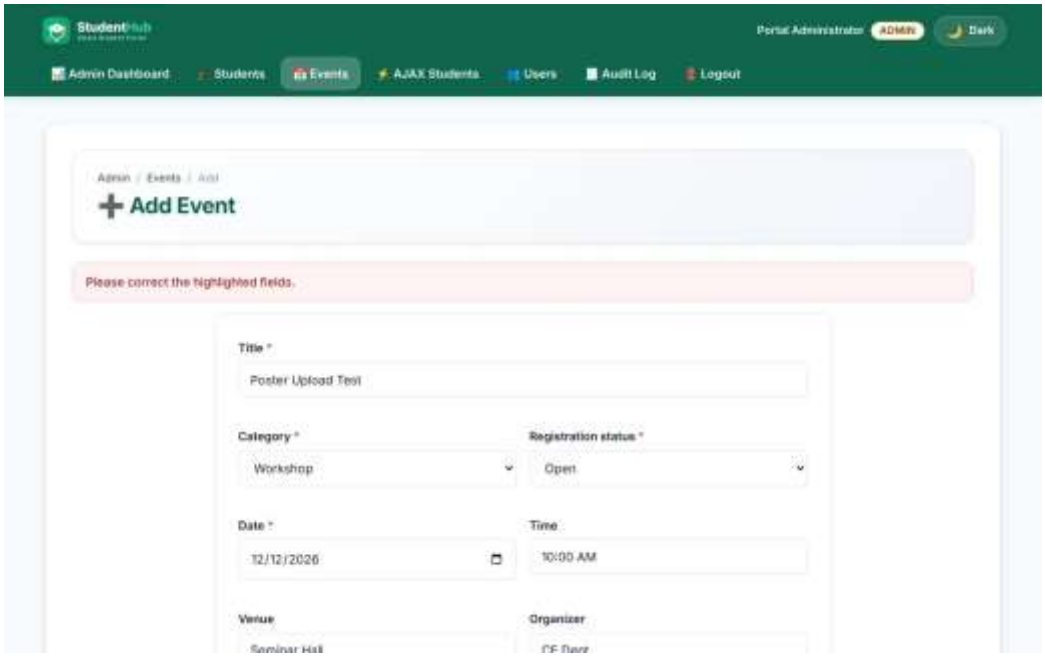
Event list with poster thumbnails



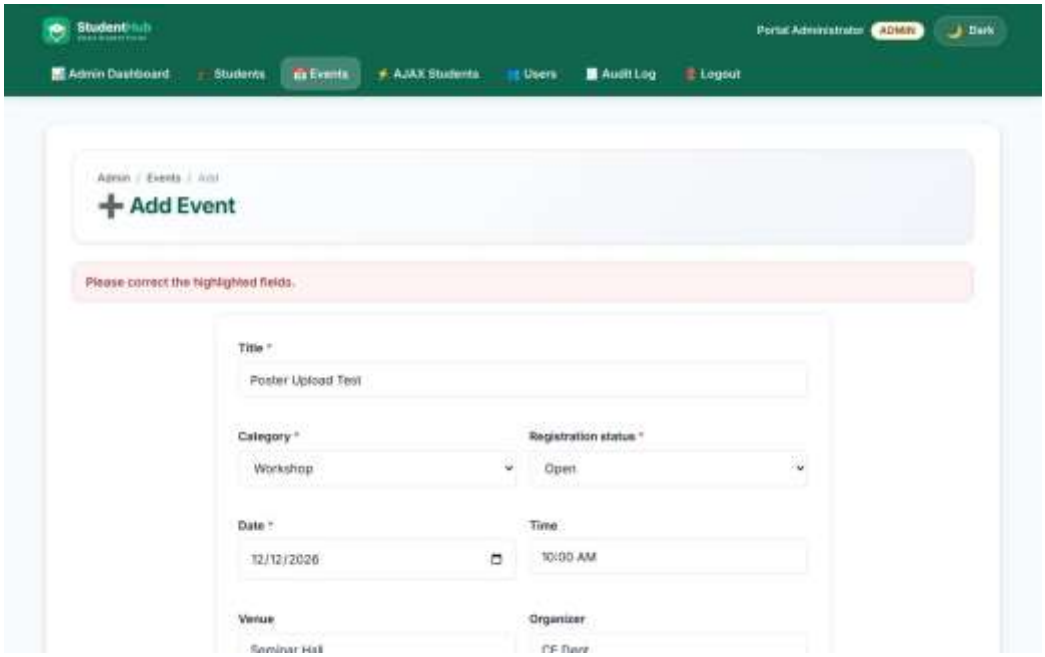
Category and open/closed filter (intermediate extension)



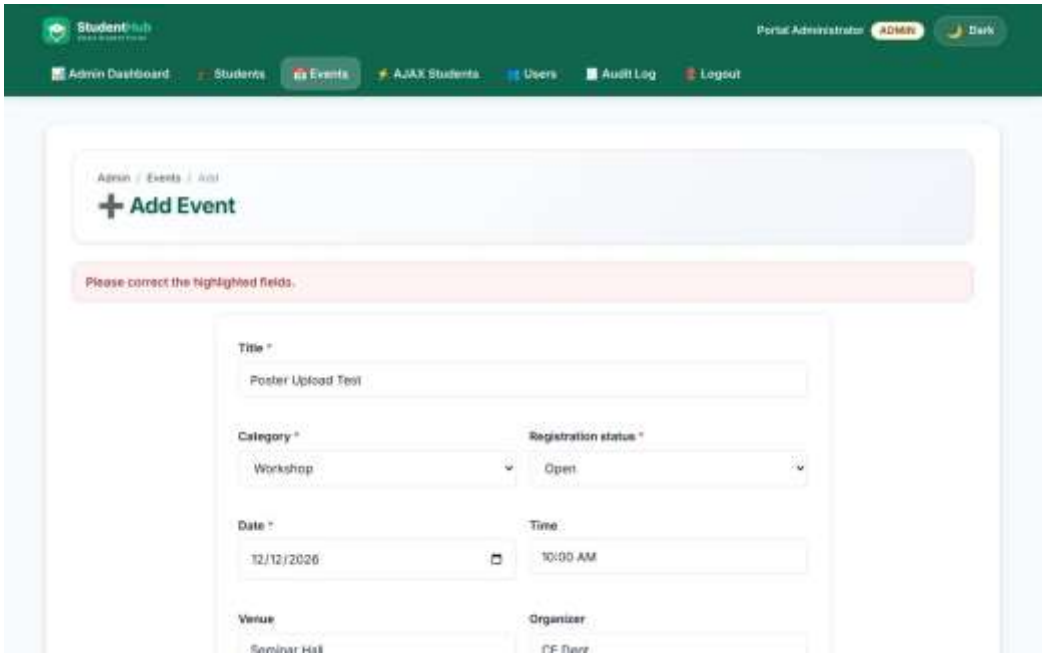
Add event form with poster field



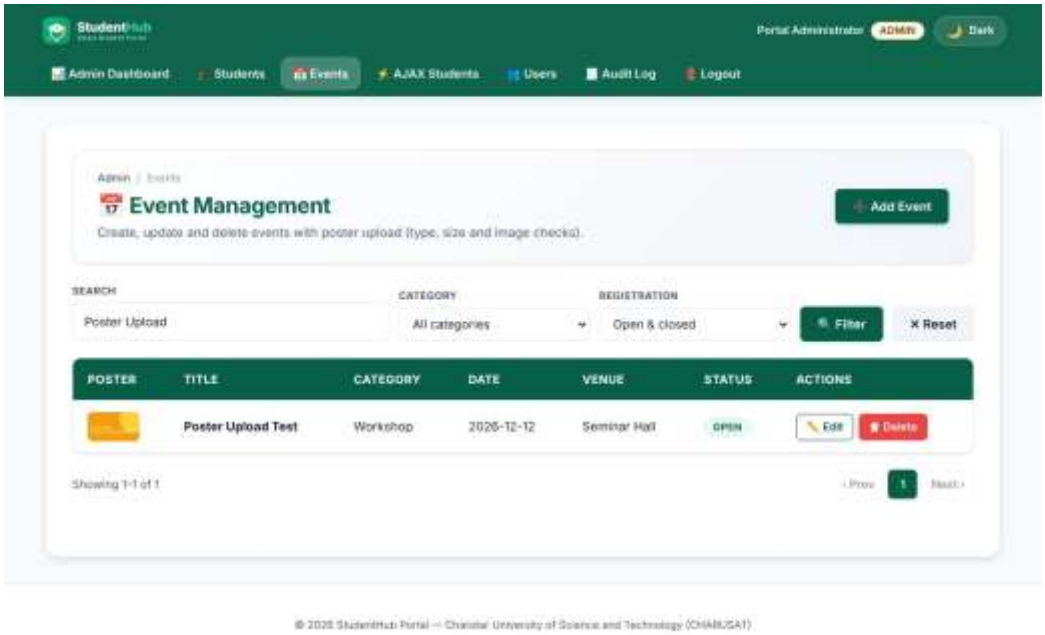
Upload validation: a PHP script renamed as a poster is rejected



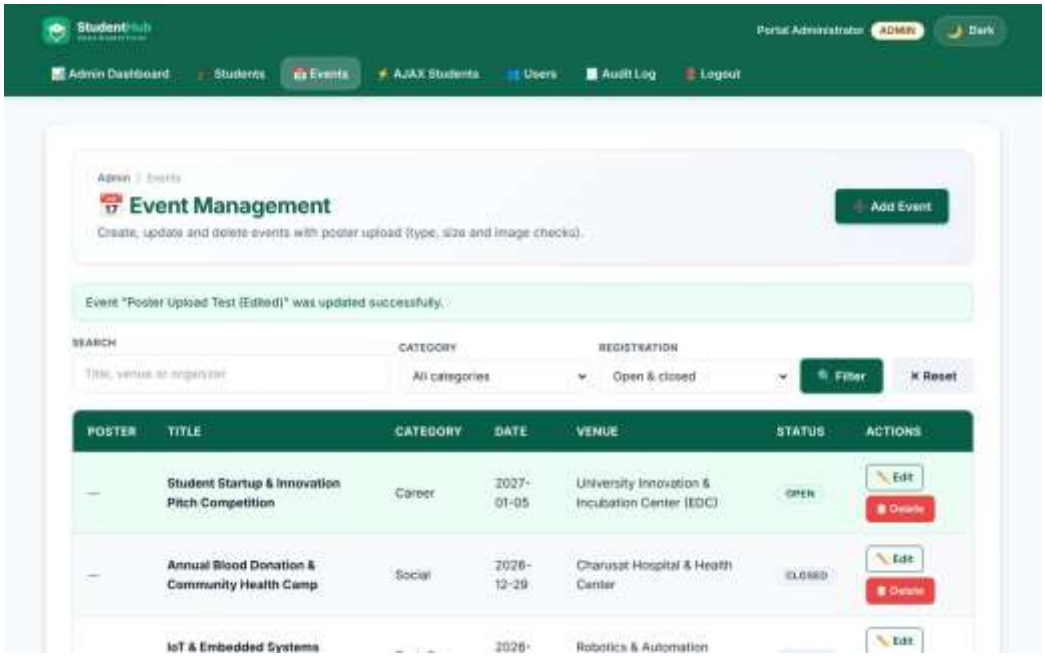
Upload validation: a text file is rejected



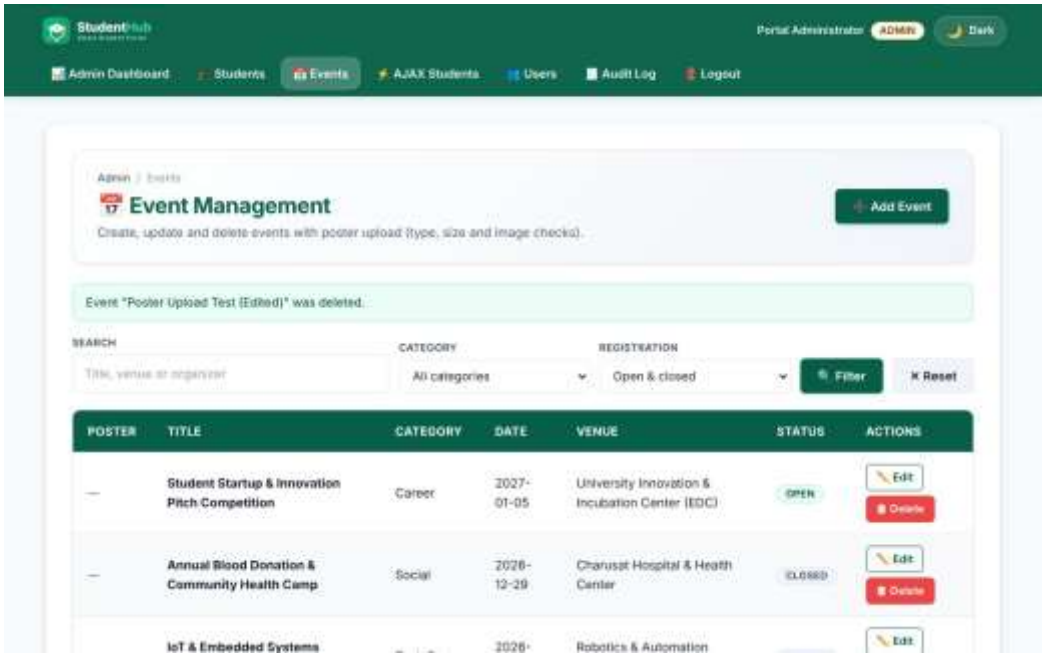
Upload validation: a file larger than 2 MB is rejected



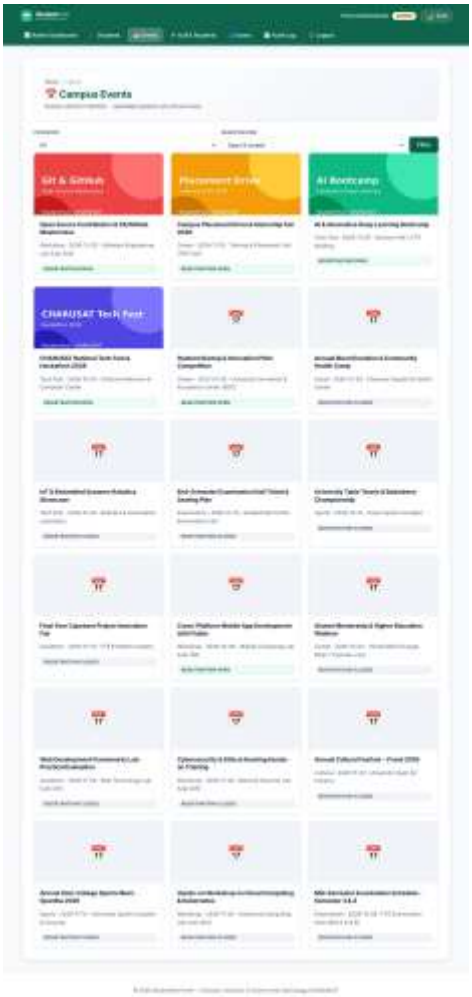
INSERT: event added with a valid JPG poster



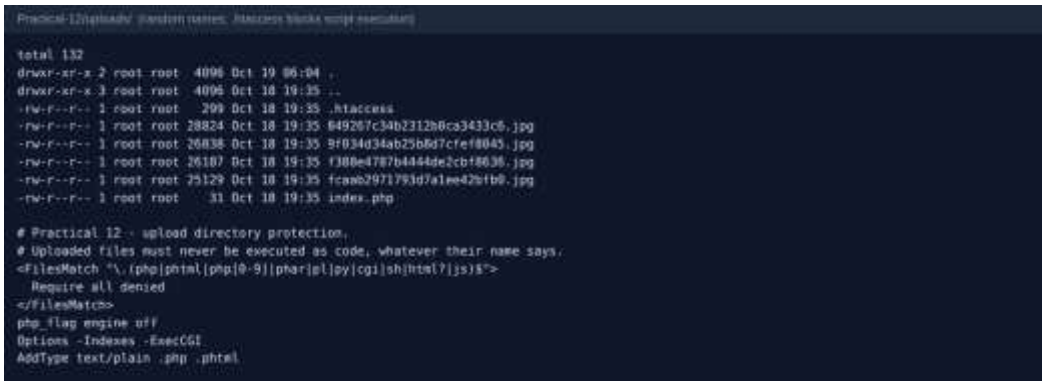
UPDATE: event edited (status closed)



DELETE: event and its poster file removed



Public events page reading from MySQL with posters



```
total 132
drwxr-xr-x 2 root root  4096 Oct 19 06:04 .
drwxr-xr-x 3 root root  4096 Oct 18 19:35 ..
-rw-r--r-- 1 root root   299 Oct 18 19:35 .htaccess
-rw-r--r-- 1 root root 28824 Oct 18 19:35 049267c34b2312b0ca3433c6.jpg
-rw-r--r-- 1 root root 26838 Oct 18 19:35 9f034d34ab25b8d7cfef8045.jpg
-rw-r--r-- 1 root root 26187 Oct 18 19:35 f380e4787b4444de2cbf8636.jpg
-rw-r--r-- 1 root root 25129 Oct 18 19:35 fcaab2971793d7a1ee42bfb0.jpg
-rw-r--r-- 1 root root    31 Oct 18 19:35 index.php

# Practical 12 - upload directory protection.
# Uploaded files must never be executed as code, whatever their name says.
<FilesMatch "\.(php|phtml|php[0-9]|phar|pl|py|cgi|sh|html?|js)$">
  Require all denied
</FilesMatch>
php_flag engine off
Options -Indexes -ExecCGI
AddType text/plain .php .phtml
```

Upload folder: random file names and the protective .htaccess

TEST CASES :

#	Input / action	Expected result	Result
1	Add event with valid poster (JPG)	Saved; file stored with a random name; audit log row	Pass
2	evil.php as poster	Rejected - only JPG, PNG, WEBP allowed	Pass
3	PHP code saved as fake.jpg	Rejected - real MIME type is text, not an image	Pass
4	doc.txt	Rejected	Pass
5	4 MB random image	Rejected - larger than 2 MB	Pass
6	No poster	Event saved without a poster (optional)	Pass

7	Title "x"	Error: 5-150 characters	Pass
8	Edit event, keep poster	Old poster kept	Pass
9	Edit event, upload new poster	New file saved, old file deleted	Pass
10	Delete event	Row and poster file removed; audit log row	Pass
11	Filter category = Tech Fest, status = open	Only matching events	Pass

SQL dump:

Practical-12/events_dump.sql contains the events table with 18 rows; sample_posters.sql attaches the demo posters.

KEY QUESTIONS :

1. Do add, update and delete work?

Yes. events_admin.php lists and filters events, event_form.php inserts or updates (?id= decides), event_action.php deletes (POST + CSRF). Each change is written to audit_logs. If saving to the database fails after a file was stored, the new file is deleted again so no orphan files remain.

2. Is the UI linked to the database?

Yes. The admin list and the public gallery (events_public.php) are both read from the events table; the poster column stores only the file name and poster_url() builds a safe URL from it. Category and status come from white-lists (CATEGORIES, open/closed).

3. Are uploads validated for type and size?

Yes, in save_poster(): (1) the PHP upload error code is checked; (2) size <= 2 MB (also limited in the form with MAX_FILE_SIZE); (3) the real MIME type is read from the file content with finfo, not from the name the browser sends; only image/jpeg, image/png and image/webp pass; (4) getimagesize() must succeed, proving it is a real image; (5) the stored name is random (bin2hex(random_bytes(12))) with the extension taken from the detected MIME type, so a user can never choose the file name or extension.

```
$mime = (new finfo(FILEINFO_MIME_TYPE))->file($file['tmp_name']);
if (!isset(POSTER_TYPES[$mime])) return [null, 'Only JPG, PNG or WEBP images are
allowed.'];
if (@getimagesize($file['tmp_name']) === false) return [null, 'The file is not a valid
image.'];
$name = bin2hex(random_bytes(12)) . '.' . POSTER_TYPES[$mime];
```

4. Are success and failure messages shown?

Yes. A green flash message appears after add / update / delete (Post/Redirect/Get), and a red alert plus a message under the poster field appears for every failed validation or upload.

5. Advanced extension - image renaming, folder protection and audit log

Images are renamed randomly. Practical-12/uploads/.htaccess denies execution of .php/.phtml/.html/.js files and turns the PHP engine off in that folder, and an index.php returns 403 to avoid directory listing. Create, update and delete are recorded in audit_logs. Four sample posters are attached to seeded events by sample_posters.sql.